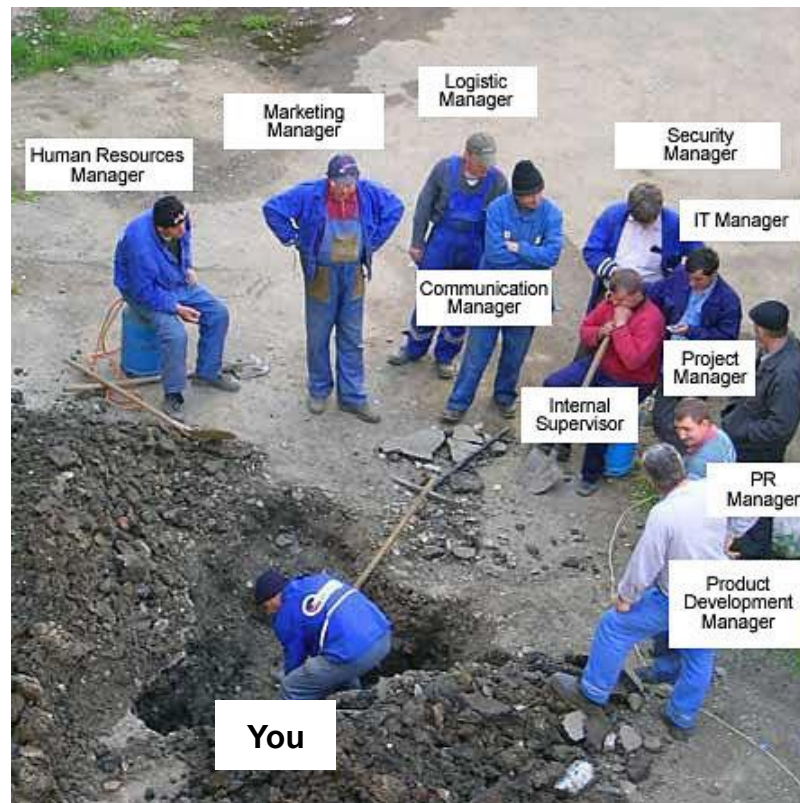




5. Risk Management

Garrison Gao

garrison.gao@uwa.edu.au

Terminology

Term	Meaning
Risk	The potential for an unwanted or adverse outcome resulting from an incident, event, or occurrence, as determined by the likelihood (or the potential) that a particular threat will exploit a particular vulnerability, with the associated consequences.
Vulnerability	A characteristic or specific weakness that renders an organization or asset (such as information or information system) open to exploitation by a given threat or susceptible to a given hazard.
Exploitation	A technique to breach the security of a network or information system in violation of security policy.
Threat	A circumstance or event (including accidental and non-human related) that has or indicates the potential to exploit vulnerabilities and to adversely impact (create adverse consequences for) organizational operations, organizational assets (including information and information systems), individuals, other organizations, or society.
Asset	A person, structure, facility, information, and records, information technology systems and resources, materials, process, relationships, or reputation allowing entities (e.g., individuals, businesses and governments) to achieve social, economic, and other objectives of value .

Definition

- ◇ **Risk:** The combination of the **likelihood (uncertainty)** of an event and its impact (Short one)
- ◇ **IT Risk:** The business risk associated with the user, ownership, operation, involvement, influence, and adoption of IT within an enterprise
- ◇ **Risk Management:** The coordinated activities to direct and control an enterprise with regard to risk.
 - ◇ **Detailed version:** Risk management is the overall process of identifying, analyzing, evaluating, and controlling risks to achieve organizational objectives. It is a continuous, cyclical process that includes planning, implementation, monitoring, and improvement (e.g., aligned with ISO 27001 or NIST frameworks).
- ◇ **Control:** The means of managing risk, including policies, procedures, guidelines, practices, organizational structures, culture, training and more, which can be of an administrative, technical, management, or legal nature
- ◇ **Internal Control:** The policies, procedures, practices, and organizational structure designed to provide reasonable assurance that business objectives will be achieved, and undesired events will be detected or corrected. (A system view)

Risk Management Lifecycle

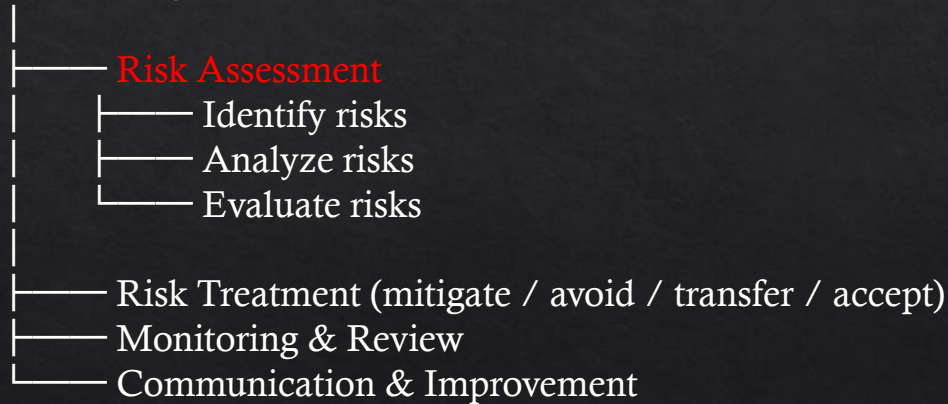
- ◇ It is a cycle
- ◇ Treatment (four actions)



Risk Management Vs Risk Assessment

- ◇ **Risk Assessment:** it is a **specific step** within **risk management** that focuses on identifying risks, analyzing their likelihood and impact, and evaluating their severity.

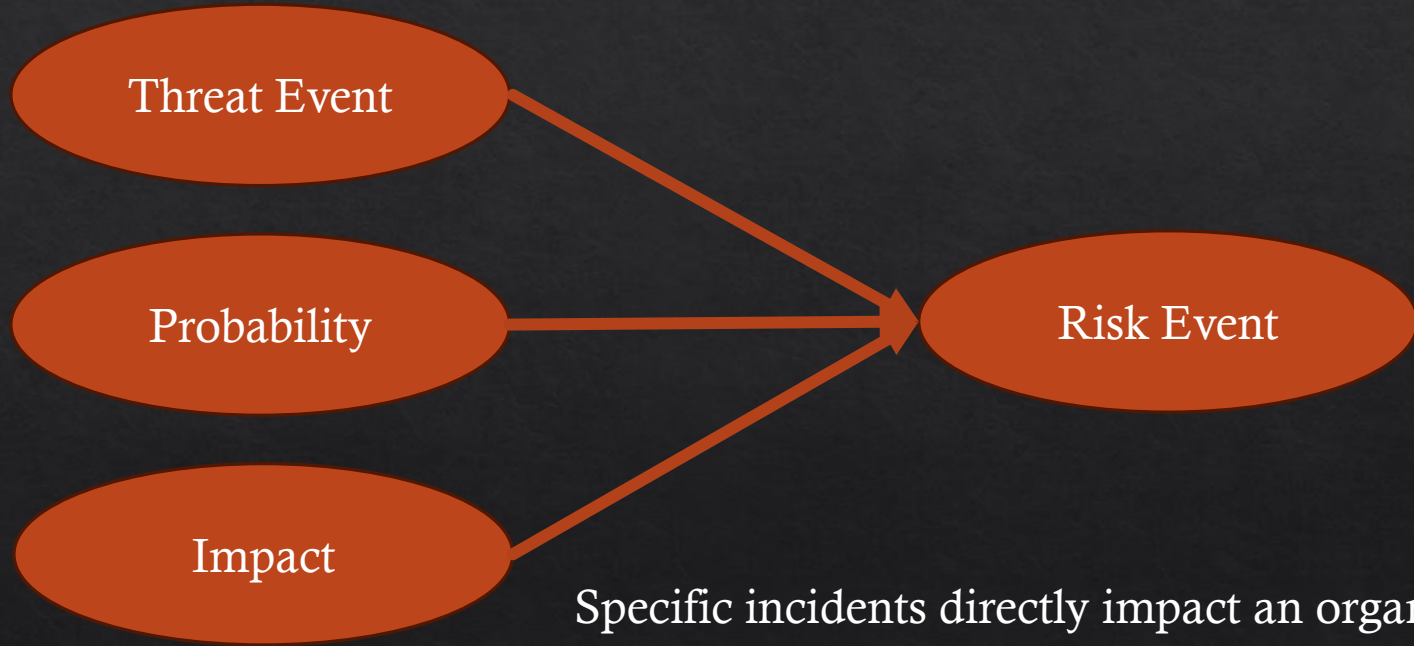
Risk Management



Risk Management Vs Risk Assessment

Aspect	Risk Management	Risk Assessment
Definition	End-to-end process of managing risks (what are we going to do about it?)	Process of identifying and analyzing risks (what could go wrong?)
Scope	Broad (strategic + operational)	Narrow (focused analysis step)
Purpose	Ensure risks are controlled and aligned with objectives	Understand risk severity and likelihood
Main Activities	Assessment, treatment, monitoring, reporting	Identification, analysis, evaluation
Output	Risk treatment plans, policies, controls	Risk levels, risk rankings, risk register
Timeframe	Continuous lifecycle	Periodic or event-driven
Decision Role	Drives decisions and actions	Provides input for decisions
Standards Context	Full ISMS (e.g., ISO/IEC 27001)	Core component within ISMS (e.g., NIST SP800-30)
Example	Implementing security controls after identifying threats	Estimating likelihood of a data breach

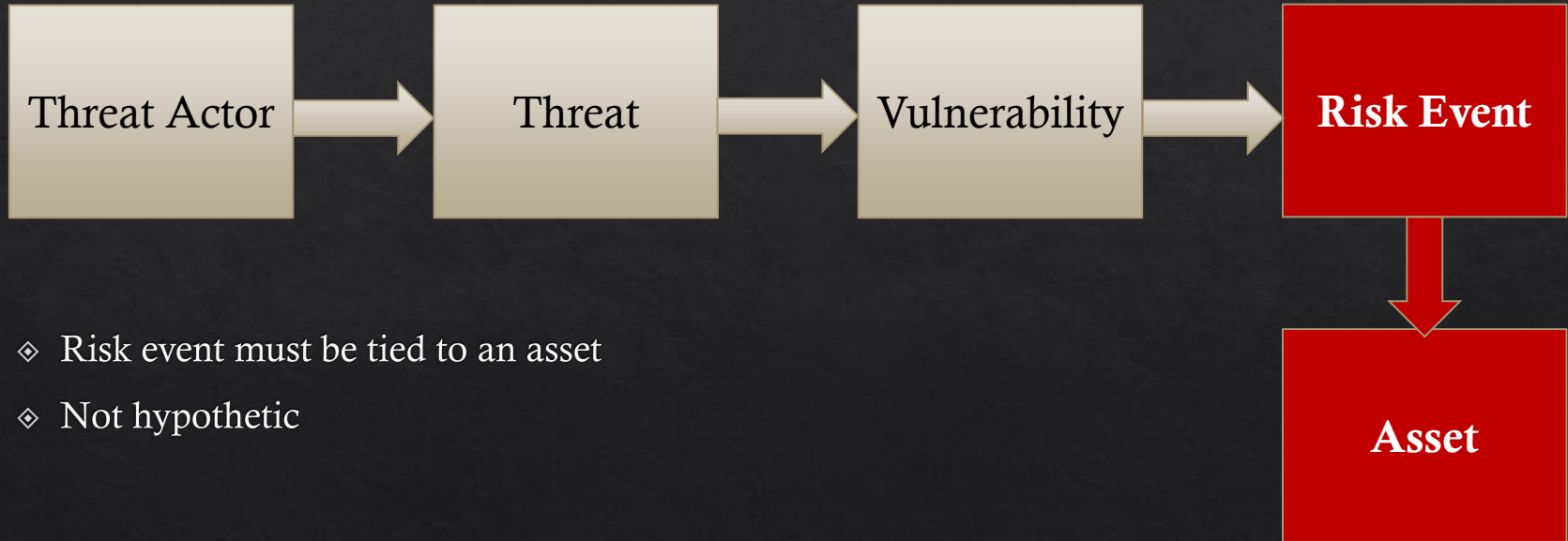
Risk Events



Definition

- ◇ Threat Event (theoretical potential) alone is not a risk event
 - ◇ A password breach of a user (no harm is caused)
 - ◇ A system unavailability (Resumed after 1 second, probability is extremely low)

Threat Events Can Turn Into Risk Events



- ◇ Risk event must be tied to an asset
- ◇ Not hypothetical

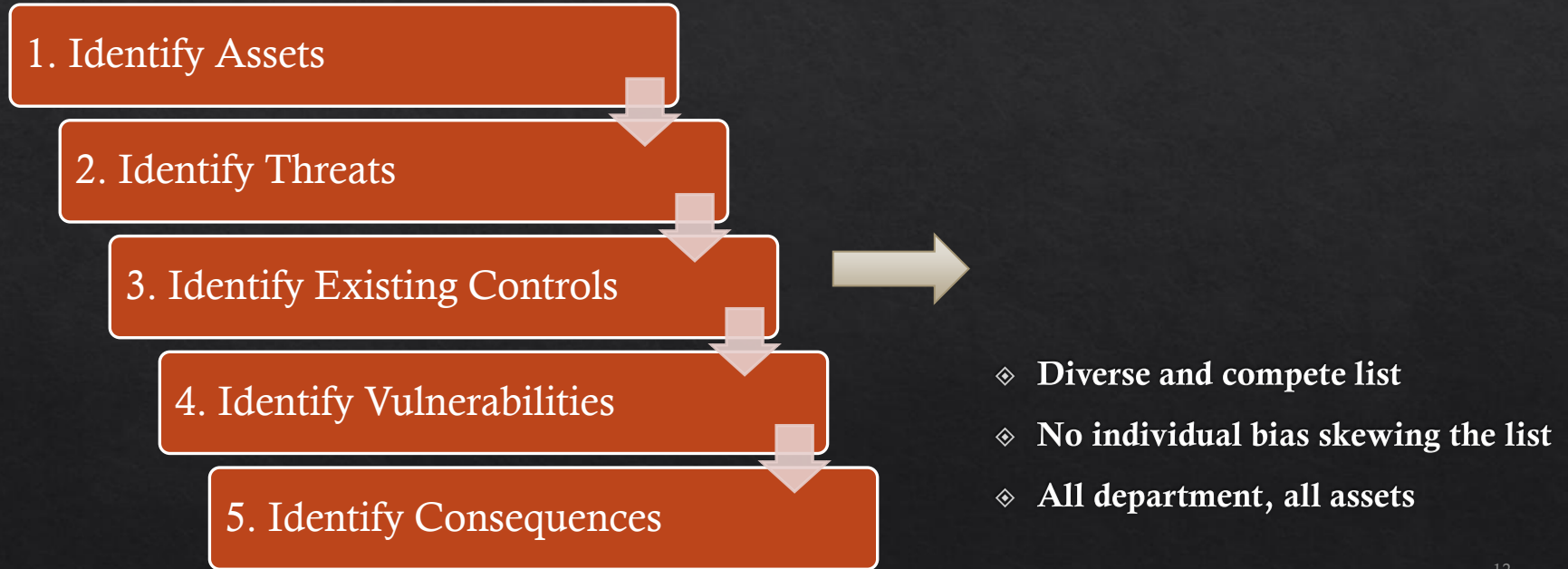
Risk Factors

Contextual Factors	Capability Factors
Factors surrounding enterprise	Ability to perform IT-related activities
Internal	IT Risk management capabilities
External	IT Business/mission capabilities

Risk Factors (Examples)

Contextual Factors	Capability Factors
Economic Factors	Risk governance
Operating Model	Tooling
Financial Capacity	Risk Management

Risk Identification Process



Risk Identification Process

Methods and Approaches

- ◇ Historical/evidence-based
 - ◇ Happened in the past
 - ◇ From our competitor
 - ◇ Similar industry
- ◇ Systematic approaches (qualitative)
 - ◇ Expert opinions
 - ◇ Bring leaders together
- ◇ Inductive methods (e.g., pen testing)
 - ◇ Examining a system step by step
- ◇ Existing taxonomy (e.g., access risk, integrity risk, availability risk)

Changes to Risk Environment

There is nothing as constant as change

How those changes are going to impact risks

- ◆ Assets can change
- ◆ Threat evolves
- ◆ Controls change
- ◆ Vulnerabilities come and go
- ◆ Employee join and leave
- ◆ Impact/loss can change
- ◆ Operate model
- ◆ etc

◆ Forecast?

◆ Review Regularly?



Threat Source

Where are threats coming from?

- ❖ Internal (e.g., user, employee, contractor)
- ❖ External (e.g., hacker, bad agent)
- ❖ Intentional (e.g., purposed)
- ❖ Accidental (e.g., typo when entering email address expose sensitive data, configuration error using a version with vulnerabilities)
- ❖ Emerging threats (e.g., OpenClaw)
- ❖ Environment threats (e.g., earthquake hit a data centre storing our data, a critical employee works there)



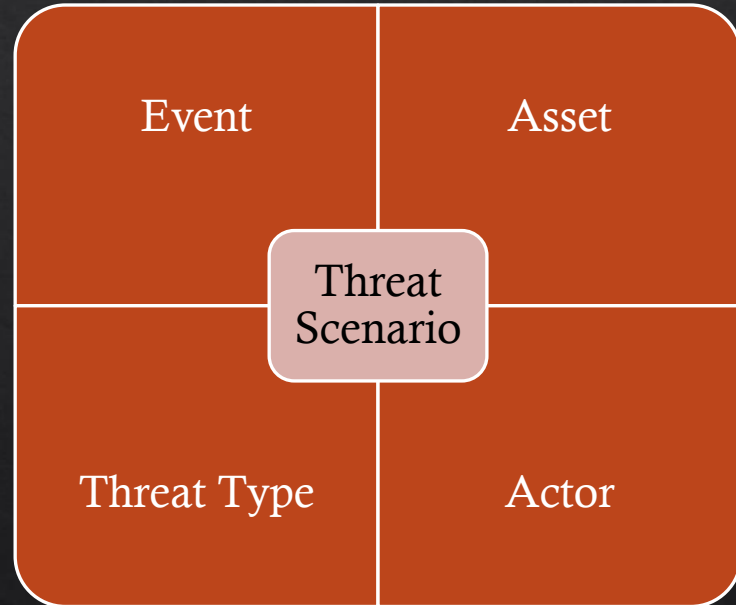
Sources for Aggregating Threat Information

- ◇ Diverse
- ◇ Complete

Conducting interviews	Media Reports	Logs
History	User Feedback	Industry Publication
Reports	Insurance Companies	Audits
Government Publications	Self-Assessment	Service Providers

Threat Scenario & Modelling

- ◇ How often will this happen?
- ◇ What skill/circumstances/time does the actor need?
- ◇ What resources are needed?
- ◇ What level of effort is required?



Vulnerabilities

- ◇ Vulnerabilities are **weakness**, **gaps**, or **holes** in an enterprise's **people**, **processes**, or **technologies** that can be exploited and create **consequences** and **impacts** for an organization.



Vulnerability Sources

Systems (e.g., unpatched)	Network	Supply Chain
Equipment/BYOD	Could	Utilities
Physical Access	AI	Big Data

Vulnerability Assessment & Ranking

- ◆ Tests to see where our vulnerabilities are
- ◆ Automated (pen testing) or manual (process walkthrough, discussion)
- ◆ Clearly stated objective of assessment

- ◆ CVSS (Common Vulnerability Scoring System) ranking methodology
- ◆ Do you need your own? (need to fit your needs, to help your own organization)
- ◆ Root cause analysis (e.g., coding error, releasing error, configuration error, or human?)

IT Risk Scenarios

- ◇ Telling a story once the event, threat, asset, actor are identified
- ◇ Purpose:
 - ◇ Help visualize the risk
 - ◇ Ask for funding or support (money, human) to have the controls done and implemented?
 - ◇ get buy-in from stakeholders?

Risk Scenarios

Two systematic ways of creation

◇ **Top down**

- ◇ From business goals down to risk
 - ◇ Supporting more customers vs availability scenario
 - ◇ Critical marketing time vs customer data loss
 - ◇ Retail organization vs outage on Black Friday



◇ **Bottom up**

- ◇ From risk events to enterprise impact
 - ◇ Unauthorized access, data breaches recently happened to our competitor vs indicates to our organization
 - ◇ Usage of emerging technology (e.g., Openclaw), causing harms



Realistic and get buy-in

Risk Scenarios

- ◇ Script should have

Actor	Intent/motivation
Asset	Effect
Loss magnitude (e.g., financial, reputation)	Threat event
Frequency/Likelihood	Resources (attacker, defender)

Risk Assessment Techniques

- ◇ Many risk assessment techniques to choose from (But what is suitable for your organization?)
- ◇ Consistency over time (across department) can pay off
 - ◇ As it's hard to compare risk then
- ◇ What techniques is best for?
 - ◇ Your organization model?
 - ◇ The risk culture (awareness, how well it is understood)?
 - ◇ The circumstances (do you have full time risk practitioner, tools, by third-party)?
 - ◇ The assessment type (report, powerpoint, who do we report to)?



Risk Assessment Techniques

- ◆ Quantitative (Scientific)
 - ◆ Numeric
- ◆ Qualitative (Art)
 - ◆ Survey based, expert-based, scenario-based
 - ◆ Level (e.g., high, medium, low)



Risk Assessment Techniques

- ◇ **Monte Carlo Analysis**: Statistical analysis to generate numbers for assessment
- ◇ **Bayesian Analysis**: Statistical analysis to create distribution data
- ◇ **Factor Analysis of Information Risk (FAIR)**: Taxonomy of factors & how they affect each other
- ◇ **Delphi Method**: Expert opinions during questionnaires to build consensus
- ◇ **Event Tree Analysis**: Inductive reasoning to assess the probability of events

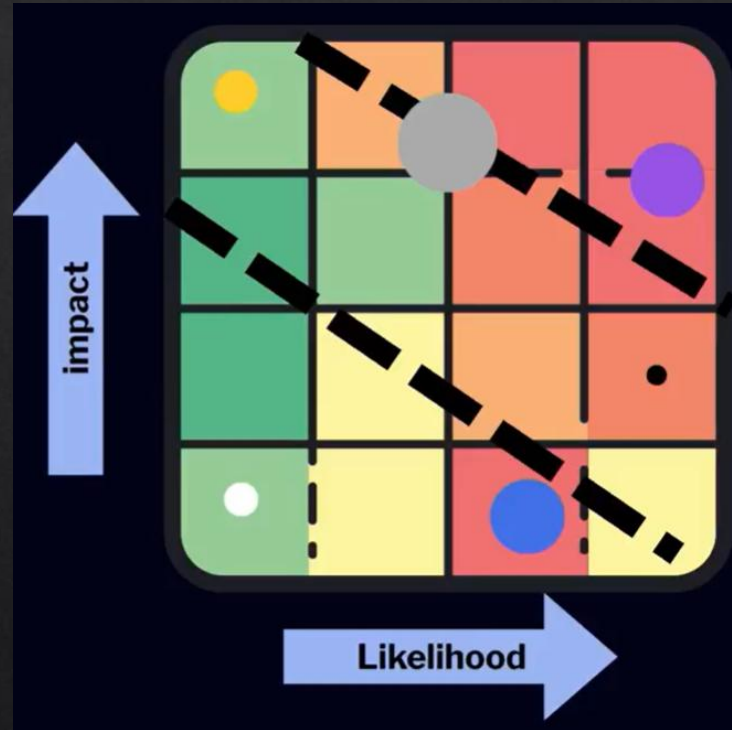
Risk Ranking

- ◇ How do we rank risk to ensure we are appropriately treating risk?
- ◇ Documenting the results of the ranking to ensure alignment (across e.g., the organization, even everyone) to avoid dispute or disagreement.
- ◇ Risk ranking report may be influenced by the needs of the company & people involved
 - ◇ Executive (short executive summary)
 - ◇ Business leader (25 page report include how, method etc)
 - ◇ CISO



Risk Ranking Example

◇ Heatmap



Risk Ownership

- ◆ Each risk (correspondingly control) must be owned by an individual (e.g., tied to title, department, essentially an individual), ensuring the risks being taken care of
- ◆ Attributes determine who owns the risk: Budget, authority (make decisions, things done), and mandate (select appropriate response)
- ◆ How to incorporate into job responsibilities?
- ◆ What level is appropriate for the risk? (executive, senior leader, IT engineering?)

Risk Ownership and Accountability

- ◆ Each risk (correspondingly control) must be owned by an individual (e.g., tied to title, department, essentially an individual)
- ◆ Attributes determine who owns the risk: Budget, authority (make decisions, things done), and mandate (select appropriate response)
- ◆ How to incorporate into job responsibilities?
- ◆ What level is appropriate for the risk? (executive, senior leader, IT engineer?)

Is not....

- ◆ The risk practitioner (unlikely have budget, authority, and mandate)
- ◆ An expert on all things off the bat
 - ◆ Know when a help is needed, understand the threshold and monitoring it to seek help
- ◆ Secondary (i.e., to be focused)

Risk Register

- ◇ Log and document the risk in to e.g., a repository, so that people can see and know
 - ◇ The biggest risk is the unknown one
 - ◇ So well documentation and research, understanding are important

- ◇ **Key Information**



Severity	Owner	Source
Impact	Risk Treatment	Last Assessed Date
Identified Date	Category	Rating
Description	Metrics	Gaps/Issues/Action Plans

- ◇ Who can access (gap is sensitive)?
- ◇ Placeholder for new risk reported

Inherent, Residual, and Current Risk

- ◆ **Inherent Risk:** Risk level or exposure without considering the actions management has taken (i.e., first time)
 - ◆ House fire no fire alarm, extinguisher considered, insurance
 - ◆ Unauthorized access without complex password, MFA
- ◆ **Residual Risk:** Risk level that remains after implementation a risk response
 - ◆ After implementing response e.g., at least 8 digits combinational password, regularly update, MFA
- ◆ **Current Risk:** Point-in-time assessment of risk
 - ◆ Factors have changed: e.g., the impact changes, risk is lower
 - ◆ Control is inefficient (password is breached through phishing), risk is higher

Risk Response and Selection

Acceptance	Mitigation	Transfer	Avoidance
Do Nothing	Control/Mitigating	Share (e.g., insurance)	Don't Engage (e.g., with risk related activities)

Risk Response and Selection

Considered Factors When Choosing Response

- ◆ Internal Factors (e.g., risk appetite, priority, policy)
- ◆ External Factors (e.g., Regulations, law compliance, contractual requirements)
- ◆ Budget
- ◆ Other actions already in flight (e.g., software is going to be replaced in 12 months)
- ◆ Past results (have responses address the risk happened previously, has insurance covered our loss)

Third Party Risk & Control

- ◇ Software supplier
- ◇ Infrastructure provider (e.g., utility)
- ◇ Cloud provider
- ◇ Licenses requirement



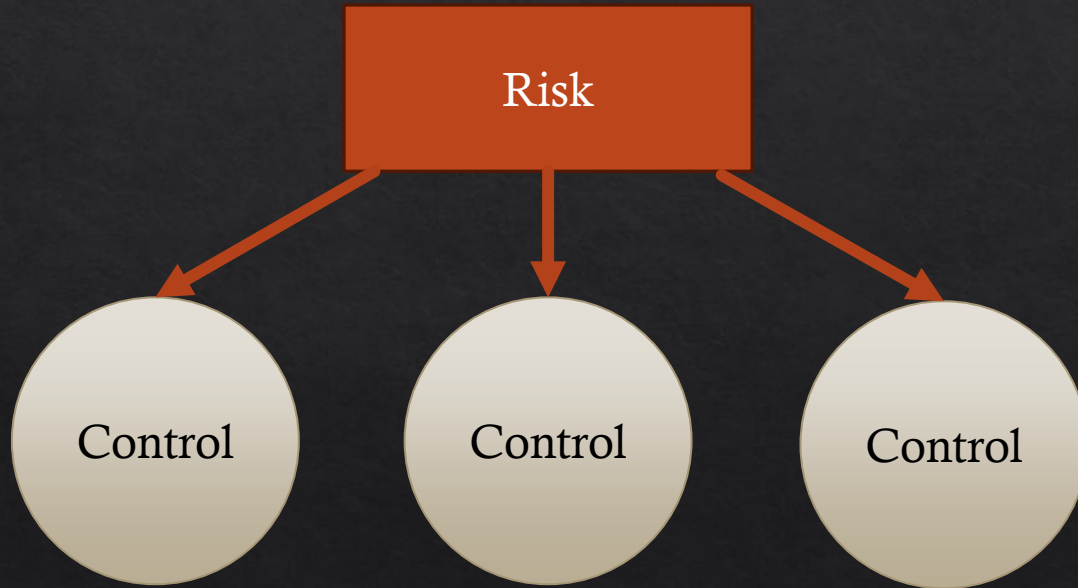
Third Party Risk & Control

But outsourcing does not lessen your risk!!!!

(Babysitter example)

- ◇ Risk can be mitigated and created through third-party relationships
- ◇ Understand contracts and monitoring
 - ◇ Lack of transparency
- ◇ AI and emerging technology impacts
 - ◇ Your contract with a third party company did not state that AI cannot be used as it was signed several years ago

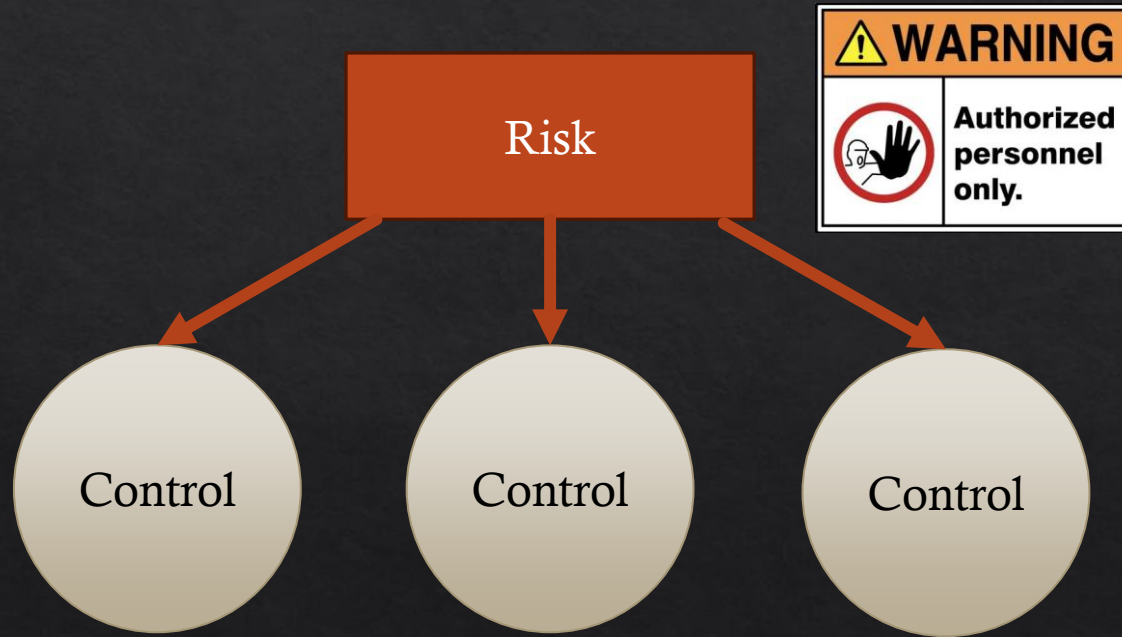
Control Standards



Control Standards

- ◇ Best Practices (e.g., access control against unauthorized access)
- ◇ Requirements (dealing with credit card subject to Payment Card Industry, PCI, requirements)
- ◇ Combination

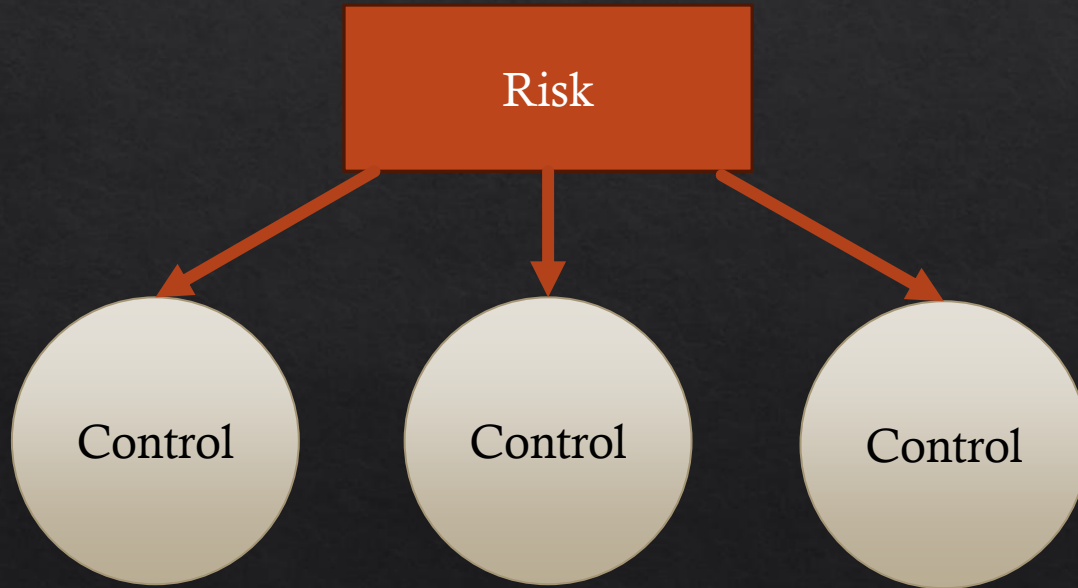
Control Categories



Control Categories

- ◇ Deterrent (warning sign)
- ◇ Preventative (Authentication)
- ◇ Compensating (e.g., backup)
- ◇ Detective (already happened)
- ◇ Corrective (e.g., Retrieve/disable an authorized access)

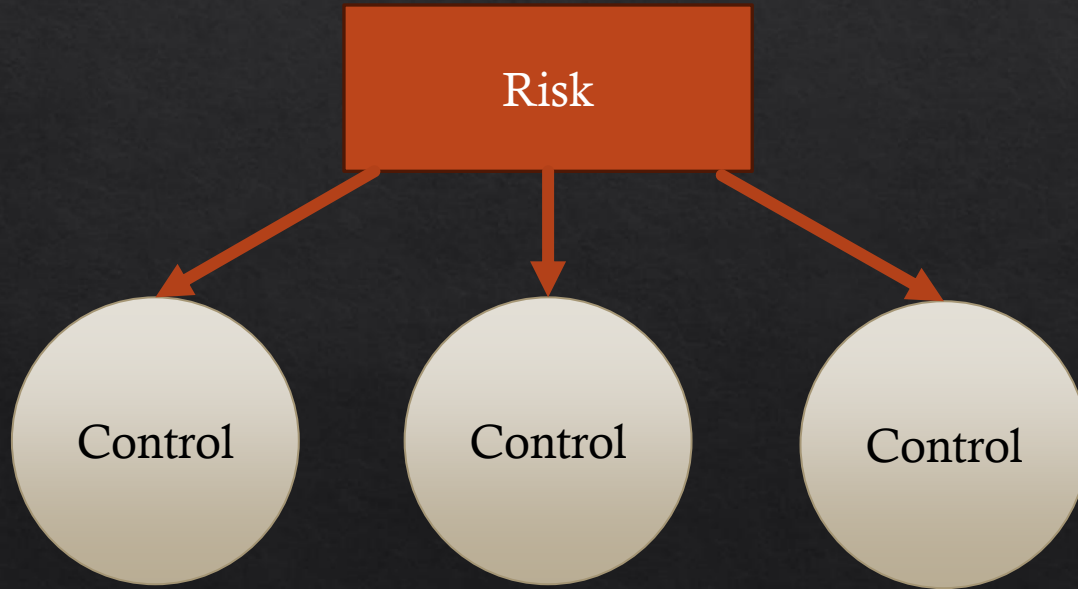
Control Categories



Control Methods (how it is performed)

- ◇ Administrative
 - ◇ Policies, procedures
 - ◇ Training
- ◇ Technical
- ◇ Physical

Control Design and Selection



- ◇ What is the current risk level?
- ◇ What's going well? Where do we need to improve?

Control Design and Selection

Example

- What is our current risk in comparison to our risk appetite and tolerances?

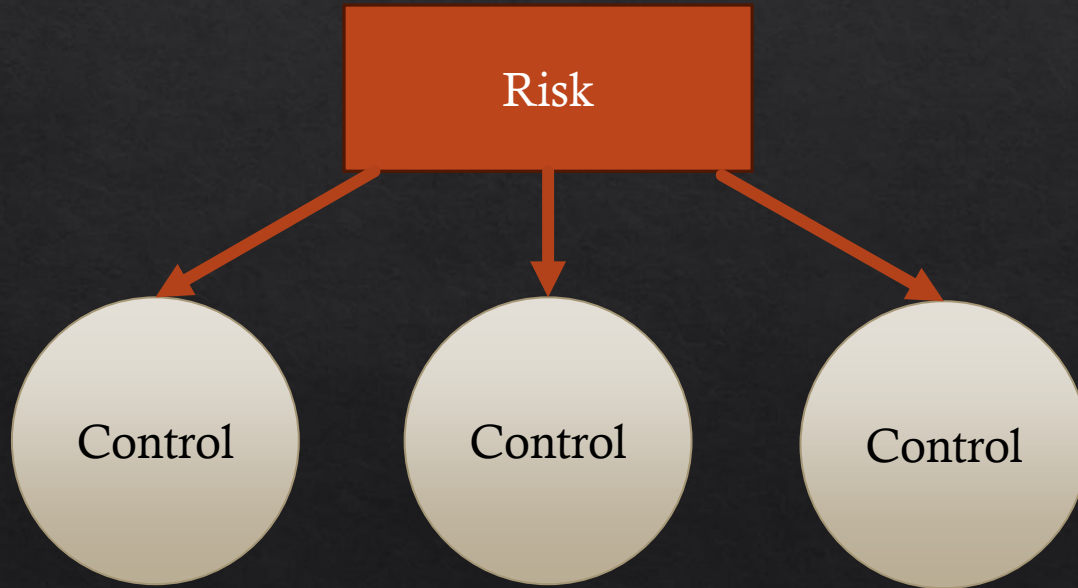


Control Design and Selection

Control selection factor consideration

- ◇ \$\$\$\$ / ROI (return of investigation)
- ◇ Technology/people in place needed
 - ◇ Tools available
 - ◇ Hire more people
- ◇ Framework/requirements (e.g., regulation mandatory, optional?)
- ◇ Business/process/throughput considerations (e.g., zero trust vs throughput)
- ◇ Compensating controls (e.g., data loss prevention system vs adds-on)

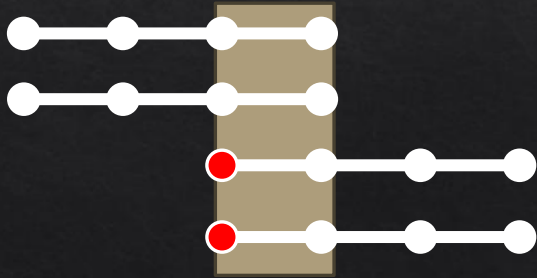
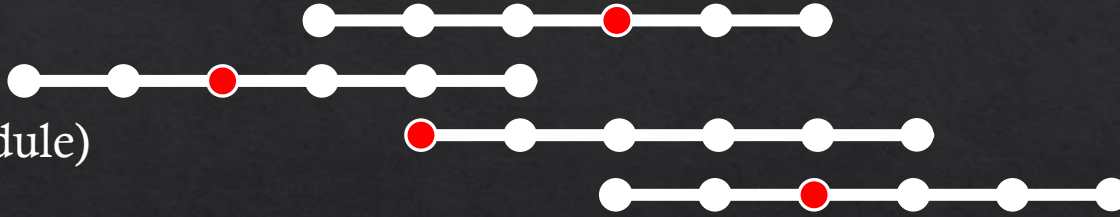
Control Documentation



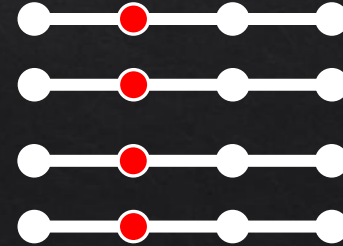
- ◇ Formal Documentation
 - ◇ Risk aren't real unless documented
 - ◇ Procedural, design, actual execution documentation
 - ◇ Be consistent to execute and monitor the control
- ◇ Training requirements
 - ◇ Type of documentation is important, being able to cross-train
 - ◇ Ensure continuity of services
- ◇ Monitoring, reporting and investigation

Control Implementation (Technical)

Phased
(module by module)



Parallel



Abrupt

Control Testing

- ◆ Are we implementing controls correctly?
- ◆ If we make a change to the environment? are controls implemented still functioning?
- ◆ When we combine systems and code, how is the control functioning?

Control Testing

Technical Testing Considerations:

- ◆ Progressive vs Regressive
 - ◆ New modules vs existing modules work or not
- ◆ Data (real/fake, sensitive, PII data)
- ◆ Environment (simulated/production/what version)
- ◆ Code (code review, live testing, real user testing)
- ◆ System
- ◆ UAT (user accepted testing)
- ◆ QA (Quality assurance)

Non-Technical Testing Considerations:

- ◆ Progressive vs Regressive
- ◆ Data
- ◆ Frequency (e.g., operation change, approval)
 - ◆ Process documented to support
 - ◆ Communication done?
 - ◆ Everyone has a manager?
- ◆ What are we checking?

Control Data Collection and Reporting

How these controls are performing? Need data

- ◆ Is all the data available?
- ◆ Has any of the data been altered or changed
- ◆ Is the data in the correct format?
- ◆ Is the data based on measuring important factors?
 - ◆ Related to control performance, control design

Control Data Collection and Reporting

Data Sources

- ◆ Prior risk assessments and audits
- ◆ User feedback (e.g., comment box, Interviews)
- ◆ Tickets
- ◆ Internal control reviews
- ◆ Project documents
- ◆ External data sources
 - ◆ Media, peer organization, industry group share information with us

Control Data Collection and Reporting

- ◇ User data
- ◇ System data
- ◇ Admin data
- ◇ Device data
- ◇ Unauthorized user data



Logs



- ◇ Incident/Threat Management
- ◇ **Control performance & Monitoring**
- ◇ Compliance Violations
- ◇ Errors and other Anomalies

Who takes what actions, when

Control Data Collection and Reporting

Logs can be overwhelming, Technology can Help

- ◆ Security Information and Event Management (SIEM)
 - ◆ Can detect attacks based on heuristics
 - ◆ What is the speed of the correlation engine?
- ◆ Detection/Response Technologies
 - ◆ Endpoint Detection and Response (EDR): Intelligence mixed with ML
 - ◆ Extended Detection and Response (XDR): United view of endpoints with servers, cloud and networks
 - ◆ Managed Detection and Response (MDR): Combination of technology and service provider
- ◆ Integrated Test Facilities (ITF): Processes test data through production systems
 - ◆ When a new functionality is added into our system
 - ◆ Without affecting downstream process (e.g., 10 out of 20 data are fake in the upper process)

Metrics for Risks

Why metrics

- ◆ Qualitative vs Quantitative
- ◆ Objective measurement
- ◆ Not all metrics are key!
 - ◆ Understand root cause, concerns, attributes that are playing in our environment, so what needs to be measured
- ◆ Can help measure existing (inherent, residual, current risk level), also future, or emerging risk

Metrics

Key Performance Indicator (KPI)	Key Risk Indicator (KRI)	Key Control Indicator (KCI)
Goal: How well a process is performing against objectives	Goal: Measure risk levels against defined thresholds	Goal: Track performance of control activities against tolerances
KPIs should be SMART (specific, measurable, attainable, realistic and timely)	Need to balance KRI selection between leading (likelihood will happen) and lagging (likelihood already occurred), and that can help avoid risk events (e.g., number of unauthorized access, number of unpatched vulnerabilities)	KCI → likely broken control → potential risk event

Monitoring Controls & Reporting

Steps of Monitoring controls

- ◆ Identify and confirm owners
- ◆ Engage with stakeholders & communicate requirements
- ◆ Maintain monitoring approach consistently and continually
- ◆ Establish monitoring processes and procedures
- ◆ Determine lifecycle management and change control processes
- ◆ Request, prioritize and allocate resources

Exceptions should be identified and escalated to an appropriate level/manager

Monitoring Controls & Reporting

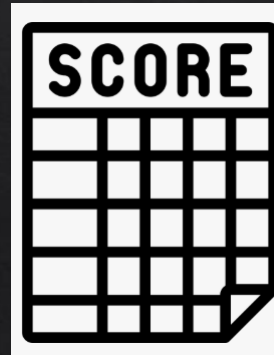
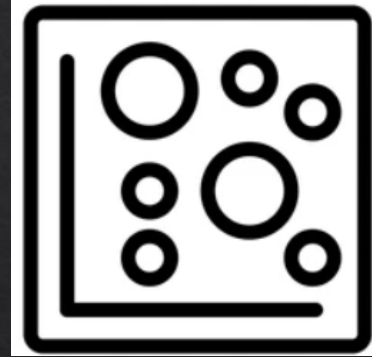
Type of control assessments

- ◆ Self-assessment
 - ◆ E.g., by the control owner
- ◆ Audit
 - ◆ Internal audit team
- ◆ Outcome based:
 - ◆ Vulnerability assessment
 - ◆ Penetration testing
- ◆ Third-party assurance
 - ◆ Third-party auditor, qualified auditor for some framework or certification required

Monitoring Controls & Reporting

What matters in reporting?

- ◇ Timeliness
 - ◇ 3 days, 30 days?
- ◇ Skills of Analyst
 - ◇ Who generate the report
- ◇ Quality & Quantity of Data
 - ◇ Can we rely on?
- ◇ Means of presentation/visualization



Monitoring Controls & Reporting

Emerging Risk Reporting

- ◆ How are we identifying and reporting new risk
- ◆ How are we monitoring for emerging technologies and their risk profiles?
- ◆ How will our controls perform with the emerging risk identified?
 - ◆ Data loss prevention tools work for AI?
- ◆ What are the vulnerabilities (e.g., of new technology) with our controls?

Standards

There are frameworks for risk assessment (NIST SP 800-30) and management (ISO/IEC 27001)

- ◆ The purpose of NIST SP 800-30 is to provide **guidance for conducting risk assessments** of federal information systems and organizations.
- ◆ ISO/IEC 27001 is the international standard for information security management. It sets out a **risk-based framework** that any organisation can use to establish, implement, operate, monitor, review, maintain and continually improve an approach to securing corporate information known as an ISMS (information security management system).

ISO/IEC 27001 (Risk Management)

How do you implement ISO 27001? Key steps

- ◆ ISO/Scoping the project.
- ◆ Securing management commitment and adequate resources.
- ◆ Identifying interested parties and applicable legal and contractual requirements.
- ◆ **Conducting a risk assessment.**
- ◆ Selecting and implementing the required controls.
- ◆ Developing internal competence to manage the project.
- ◆ Developing the appropriate documentation.
- ◆ Conducting staff awareness training.
- ◆ Continually measuring, monitoring, reviewing and auditing your ISMS.
- ◆ Implementing the necessary corrective and preventive actions.

<https://grcsolutions.io/iso27001/>

NIST SP800-30 (Risk Assessment)

- NIST SP800-30 outlines 9 risk assessment activities



NIST SP800-30

Input

- Hardware
- Software
- System interfaces
- Data and information
- People
- System mission

1. System characterisation

Looks Like



Output

- System boundary
- System functions
- System and data criticality
- System and data sensitivity

Process to profile the system

e.g., find the system configuration, dependencies, operations, usage etc.

NIST SP800-30

Input

- History of system attack
- Data from intelligence agencies, NIPC, OIG, FedCIRC, mass media, etc

2. Threat identification



Output

- Threat statement

Identify and understand possibilities of attacks to the system
e.g., latest attack methods and approaches that can violate the security requirements of the system

NIST SP800-30

Input

- Reports from prior risk assessments
- Any audit comments
- Security requirements
- Security test results

3. Vulnerability identification



Output

- List of potential vulnerabilities

Locate vulnerabilities in the system
e.g., using vulnerability scanners and IDS reports

NIST SP800-30

Input

- Current controls
- Planned controls

4. Control analysis



Output

- List of current and planned controls

Identify and evaluate the effects of current and planned security controls

e.g., authentication will protect the system from external users

NIST SP800-30

Input

- Threat-source motivation
- Threat capacity
- Nature of vulnerability
- Current controls

5. Likelihood determination



Output

- Likelihood rating

Consider the inputs to evaluate the likelihood (will someone exploit this?)

e.g., found a BoF vulnerability on a machine which is disconnected from the network

NIST SP800-30

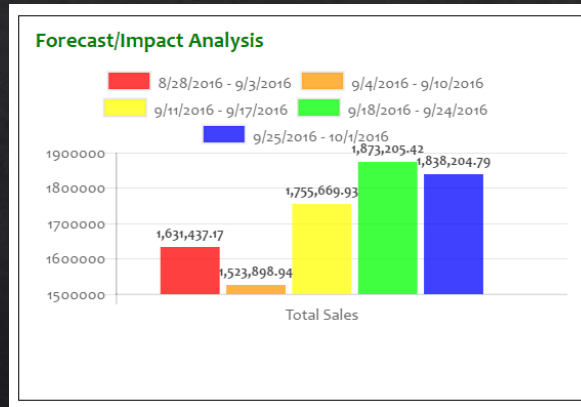
Input

- Mission impact analysis
- Asset criticality assessment
- Data criticality
- Data sensitivity

6. Impact analysis

Output

- Impact rating



To determine the significance of an attack to the system and the organisation

e.g., compromised user profile database will disable users logging into the system to carry out their tasks

NIST SP800-30

Input

- Likelihood of threat exploitation
- Magnitude of impact
- Adequacy of planned or current controls

7. Risk determination



Output

- Risks and associated risk levels

Take consideration of the risk assessment results and determine the level of the system security risk
e.g., to prioritise security control selection (next activity)

NIST SP800-30

Input

- -

8. Control recommendation

Output

- Recommended controls



Based on the risk assessment results, select the security control to implement
e.g., update firewall rules, adopt new security policy, deploy IDS etc.

NIST SP800-30

Input

9. Results documentation

Output

- Risk assessment report

IT Risk Management Plan Templates			
Risk	Risk Level	Control	Supporting Documents
Customers or staff may injure themselves on the property	High Risk	Emergency procedures followed, incident report completed, first aid kit used or doctor/hospital contacted	See Operations Manual
		Cleaning and maintenance schedules kept which ensure regular inspection of property	
		Customers verbally warned of slippery paths	See cleaning schedules in Operations Manual
		Staff induction covers safe practices and safe handling	See Greeting Procedures
		Non slip mats in bath, and on steps;	See Staff induction procedures in Operations Manual
		handrail at entrance	Installed 1/6/01, invoices on file
		Instructions written on using gas fires, electric equipment	Compendium in each room
Canoes capsize, customers fall into water	High Risk	Water Safety procedures documented and explained to each customer	Pre-tour handout to customer, also in Operations Manual
		Safety and flotation devices supplied to meet standards	
		Canoes checked for damage after every trip	See invoices for equipment
		Guides must have lifesaving qualifications, and emergency procedures	Maintenance schedule
			Personnel files + training program + Operations Manual
Property involved in a fire	Low Risk	Insurance cover for replacement	Annual renewed 1/2/02
		Smoke alarms, extinguishers installed, checked quarterly by CFA	
		Procedures written for customers, staff and managers	See diary/ maintenance schedule
			Compendiums, Operations Manual.

Conclusion

- ◆ Risk Managements
- ◆ Risk Assessment
- ◆ Risk Response and Reporting
- ◆ Frameworks

Acknowledge: ISACA Certified in Risk and Information Systems Control (CRISC)
Cert Prep, Instructor: Cybrary (They have various Cybersecurity resources)

Additional Items

- ◇ Security standards and framework
 - ◇ ISO: <http://standards.iso.org/ittf/PubliclyAvailableStandards/>
 - ◇ ISO: <http://www.iso27001security.com/index.html>
 - ◇ NIST: <https://www.nist.gov/cyberframework>
 - ◇ ASD: <https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/essential-eight>